

Statement of Applicability

ISO/IEC 27001:2022 Annex A — Nexora Solutions Pvt Ltd (Hypothetical SME)

1. Purpose and Method

The Statement of Applicability (SoA) is a mandatory ISO/IEC 27001 deliverable (Clause 6.1.3(d)) that records a decision — Yes, Partial, or No — for every control in Annex A, together with a justification. It is the single most scrutinized document in a certification audit, because it is the bridge between the Risk Assessment (Section 2 of the companion Policy & Risk Assessment document) and what is actually implemented.

Decisions below reflect the current state of the Nexora case study built throughout this internship: “Yes” means the control is substantively addressed by policy or a lab deliverable produced during this work; “Partial” means an informal or incomplete version exists; “No” means the control is not currently addressed, with a note on priority. Annex A lists 93 controls across four themes: Organizational (37), People (8), Physical (14), and Technological (34).

2. Organizational Controls (A.5.1 – A.5.37)

Control	Title	Applicable?	Justification
5.1	Policies for information security	Yes	Delivered as this Information Security Policy document.
5.2	Information security roles and responsibilities	Yes	Defined via the incident escalation chain (1.4.3) and access review ownership (1.2.5).
5.3	Segregation of duties	Partial	IT admin and access-review responsibilities currently sit with the same role; formal SoD is a roadmap item.
5.4	Management responsibilities	Yes	Covered by the Policy's annual review clause (1.1.3) and management-approval requirement.
5.5	Contact with authorities	Partial	No formal authority contact list is maintained yet; recommended addition.
5.6	Contact with special interest groups	No	Not currently practiced; low priority at Nexora's current size.
5.7	Threat intelligence	Partial	Ad hoc OSINT research was conducted (threat intel brief), but no ongoing feed or process exists.
5.8	Information security in project management	Partial	Applied informally on client projects; not yet a formal project gate.
5.9	Inventory of information and other associated assets	Yes	Captured in the Risk Register (Section 2), 15 assets identified with owners.

Contr ol	Title	Applicab le?	Justification
5.10	Acceptable use of information and other associated assets	Partial	Implied within the Access Control policy; no standalone Acceptable Use Policy yet.
5.11	Return of assets	Yes	Covered under the de-provisioning requirement (clause 1.2.3).
5.12	Classification of information	No	Not yet implemented; recommended future addition.
5.13	Labelling of information	No	Dependent on 5.12; not yet implemented.
5.14	Information transfer	Partial	Covered implicitly via VPN/email controls; no standalone transfer policy.
5.15	Access control	Yes	Section 1.2 of this Policy.
5.16	Identity management	Yes	Provisioning/de-provisioning lifecycle defined (clause 1.2.3).
5.17	Authentication information	Yes	Password Policy (Section 1.3).
5.18	Access rights	Yes	RBAC plus quarterly access review (clauses 1.2.2, 1.2.5).
5.19	Information security in supplier relationships	No	Not yet addressed; Nexora's own suppliers (e.g. hosting) not formally assessed.
5.20	Addressing information security within supplier agreements	No	Depends on 5.19; not yet implemented.
5.21	Managing information security in the ICT supply chain	Partial	CI/CD pipeline hardening (Risk 3 treatment) partially addresses this.
5.22	Monitoring, review and change management of supplier services	No	Not yet implemented.
5.23	Information security for use of cloud services	Partial	Addressed via the cloud environment risk treatment (Risk 4); no standalone cloud policy.
5.24	Information security incident management planning and preparation	Yes	Incident Reporting Policy (Section 1.4) and separate Incident Response Playbook.
5.25	Assessment and decision on information security events	Yes	Severity classification scale (clause 1.4.2).
5.26	Response to information security incidents	Yes	Escalation chain (clause 1.4.3).
5.27	Learning from information security incidents	Yes	Monthly incident review requirement (clause 1.4.4).
5.28	Collection of evidence	Partial	Incident register exists (1.4.4); no formal forensic evidence-handling procedure defined.
5.29	Information security during disruption	No	No formal continuity plan; flagged as future work.
5.30	ICT readiness for business continuity	No	Not implemented; flagged under the CSF "Recover" gap (clause 1.5).
5.31	Legal, statutory, regulatory and contractual requirements	Partial	Referenced generally (72-hour client notification, clause 1.4.3); no maintained compliance register.
5.32	Intellectual property rights	Partial	Addressed indirectly via the source-code repository risk (Risk 2); no standalone IP policy.

Contr ol	Title	Applicab le?	Justification
5.33	Protection of records	Partial	Covered under the CRM/database risk treatment (Risk 6); no formal retention schedule.
5.34	Privacy and protection of PII	Partial	CRM hardening plan addresses PII exposure; no standalone privacy policy.
5.35	Independent review of information security	No	Not yet conducted; annual third-party review recommended.
5.36	Compliance with policies, rules and standards for information security	Yes	Addressed via the accompanying Internal Audit Checklist.
5.37	Documented operating procedures	Partial	Some procedures documented (backup, access review); not yet comprehensive.

3. People Controls (A.6.1 – A.6.8)

Contr ol	Title	Applicab le?	Justification
6.1	Screening	No	Not currently practiced; recommended for privileged/admin roles.
6.2	Terms and conditions of employment	Partial	Standard employment contracts assumed; security clauses not confirmed.
6.3	Information security awareness, education and training	Partial	Phishing simulation conducted (Task 3.1); no recurring training program yet.
6.4	Disciplinary process	No	Not addressed in this Policy; recommended HR-policy addition.
6.5	Responsibilities after termination or change of employment	Yes	Covered by the de-provisioning clause (1.2.3).
6.6	Confidentiality or non-disclosure agreements	Partial	Client NDAs assumed standard; employee-level NDA not confirmed.
6.7	Remote working	Partial	Addressed indirectly via VPN/MFA controls (Risk 8); no standalone remote-work policy.
6.8	Information security event reporting	Yes	Incident Reporting Policy (clause 1.4.1).

4. Physical Controls (A.7.1 – A.7.14)

Contr ol	Title	Applicab le?	Justification
7.1	Physical security perimeters	Partial	Office premises assumed secured; not formally documented.
7.2	Physical entry	Partial	Badge system exists (Risk 10); no visitor sign-in process.
7.3	Securing offices, rooms and facilities	Partial	General office security assumed; infrastructure is cloud-hosted, no on-prem server room.
7.4	Physical security monitoring	No	No CCTV currently; recommended as part of Risk 10 treatment.

Control	Title	Applicable?	Justification
7.5	Protecting against physical and environmental threats	No	Low priority — infrastructure is cloud-hosted, not on-premises.
7.6	Working in secure areas	No	Not applicable; no defined secure areas beyond the general office.
7.7	Clear desk and clear screen	No	Not yet formalized; low-cost future addition.
7.8	Equipment siting and protection	Partial	Standard office equipment placement; not formally risk-assessed.
7.9	Security of assets off-premises	Yes	Addressed via the developer-laptop encryption/EDR control (Risk 1).
7.10	Storage media	No	Not addressed; low current use of removable media assumed.
7.11	Supporting utilities	No	Not applicable at current scale — no on-premises data center.
7.12	Cabling security	No	Not applicable — infrastructure is cloud-hosted.
7.13	Equipment maintenance	No	Not addressed.
7.14	Secure disposal or re-use of equipment	No	Not addressed; recommended given laptop/BYOD risk (Risks 1, 12).

5. Technological Controls (A.8.1 – A.8.34)

Control	Title	Applicable?	Justification
8.1	User end point devices	Yes	Developer laptop control — encryption/EDR (Risk 1).
8.2	Privileged access rights	Yes	PAM recommendation for admin accounts (Risk 15).
8.3	Information access restriction	Yes	RBAC (clause 1.2.2).
8.4	Access to source code	Yes	Repository access controls (Risk 2 treatment).
8.5	Secure authentication	Yes	MFA requirement (clauses 1.2.4, 1.3.3).
8.6	Capacity management	No	Not addressed; low priority at current scale.
8.7	Protection against malware	Yes	EDR/endpoint deployment (Task 2.2).
8.8	Management of technical vulnerabilities	Yes	VAPT program (Task 2.3).
8.9	Configuration management	Partial	Cloud IAM hardening (Risk 4) addresses part of this; no formal CM process.
8.10	Information deletion	No	Not addressed; recommended future addition.
8.11	Data masking	No	Not currently practiced in dev/test environments.
8.12	Data leakage prevention	No	Not implemented; recommended given source-code and CRM exposure.
8.13	Information backup	Yes	Backup storage risk treatment (Risk 11) — offline/immutable backups.
8.14	Redundancy of information processing facilities	No	Cloud-provider default redundancy assumed but not formally verified.
8.15	Logging	Yes	SIEM (Wazuh) deployment (Task 2.1).

Control	Title	Applicable?	Justification
8.16	Monitoring activities	Yes	SIEM/IDS deployment (Task 2.1, Snort in Task 1.2).
8.17	Clock synchronisation	No	Default NTP sync assumed; not formally verified.
8.18	Use of privileged utility programs	No	Not addressed.
8.19	Installation of software on operational systems	No	Not addressed; change-control process recommended.
8.20	Networks security	Yes	Firewall/IDS deployment (Task 1.2).
8.21	Security of network services	Partial	VPN gateway hardened (Risk 8); broader network services not reviewed.
8.22	Segregation of networks	Partial	Lab/internal segregation demonstrated (Task 1.2); production segregation not confirmed.
8.23	Web filtering	No	Not implemented.
8.24	Use of cryptography	Yes	AES/RSA/TLS implementation (Task 3.5).
8.25	Secure development life cycle	Partial	Secure coding demonstrated (Task 3.2); no formal SDLC document.
8.26	Application security requirements	Partial	OWASP Top 10 remediation demonstrated (Task 3.2); not a formal requirements process.
8.27	Secure system architecture and engineering principles	No	Not formally documented.
8.28	Secure coding	Yes	Demonstrated via the secure web application build (Task 3.2).
8.29	Security testing in development and acceptance	Yes	VAPT/Burp Suite testing (Tasks 2.3, 3.2).
8.30	Outsourced development	No	Not applicable — no outsourced development currently.
8.31	Separation of development, test and production environments	No	Not addressed; recommended addition.
8.32	Change management	No	Not addressed; recommended addition.
8.33	Test information	No	Not addressed.
8.34	Protection of information systems during audit testing	Partial	VAPT conducted in an isolated lab (Task 2.3); production audit-testing safeguards not yet defined.

6. Coverage Summary

Across all 93 controls: 31 assessed as Yes (substantively addressed), 28 as Partial (informal or incomplete coverage), and 34 as No (not currently addressed).

- Organizational (37): 14 Yes / 14 Partial / 9 No
- People (8): 2 Yes / 4 Partial / 2 No
- Physical (14): 1 Yes / 4 Partial / 9 No

- Technological (34): 14 Yes / 6 Partial / 14 No

The concentration of ‘No’ and ‘Partial’ decisions in Physical controls is expected and appropriate: Nexora's infrastructure is cloud-hosted rather than on-premises, so controls covering data-center utilities, cabling, and environmental protection are largely not applicable at this stage. The strongest coverage is in Technological controls, reflecting the hands-on lab work completed (VAPT, SIEM, endpoint security, cryptography). The weakest coverage is in Organizational governance controls that depend on formal processes outside the scope of a single internship engagement (supplier management, independent review, business continuity) — these are flagged as prioritized next steps rather than omissions.